ONE-PAGE BRIEF

Post-quantum cryptography review: sigstore-js @ 769a53d87132

Client: Sigstore project — public repository (passive review) · Source: github.com/sigstore/sigstore-js, commit 769a53d87132 · Reviewed: 2026-10-28 18:30 UTC · Risk profile: Security software vendor

POST-QUANTUM MATURITY
Level 0 of 4
no post-quantum cryptography

FINDINGS
1 Critical **10** High **11** Medium
4 Low **2** Info

QUANTUM TIMELINE (MOSCA: X + Y − Z)
Signatures: 5 + 3 − 8 = 0 → **tight**

Next step: Inventory where classical public-key cryptography protects long-lived data and keys, and choose the first migration: usually a hybrid TLS key exchange and wrapped keys.

WHAT MATTERS MOST

Critical QSI-2026-05978	**proxy-addr 2.0.7 is affected by GHSA-jqcg-44mw-7w3h (CVE-2026-90711)** What to do: Upgrade to a fixed version (2.0.8).
High QSI-2026-05957	**Private key material present in packages/cli/src/signer.ts** What to do: Treat the key as compromised: rotate it, revoke associated certificates, remove it from version history and store keys in a secrets...
High QSI-2026-05955	**Certificate has expired ((empty))** What to do: Renew the certificate and automate renewal (e.g. ACME) with expiry monitoring.
High QSI-2026-05961	**brace-expansion 5.0.9 is affected by GHSA-6j4f-fj2g-mc7p (CVE-2026-102276)** What to do: Upgrade to a fixed version (1.1.19, 2.1.5, 3.0.7, 5.0.10).

22 more in the full report.

WHAT THE QUANTUM-VULNERABLE CRYPTOGRAPHY PROTECTS

Role	Algorithms	What to do
Low role not determined	ECDSA	Classify each usage, record data lifetimes, and plan migration to ML-DSA (FIPS 204) or SLH-DSA (FIPS 205)...

KNOWN VULNERABLE COMPONENTS

Advisories for the versions in use: 21; each needs checking against the code.

Static review of source code and manifests; files analysed: 180. No requests were sent to the owner's systems.

Full report, content SHA-256: dc5dfd0611af59e5724beaee5a3151159457f67dc81deebe8ed4ff09b683b1cb

Full report signature (report.sig.json): Ed25519 key, SHA-256 fingerprint 5b3cf9c9bd0fa54447e2b5dfa7a6bab569bd0c666fa46949599e5c348d17083e. bundle.sig.json lists the SHA-256 of every file in this bundle and is signed too; verify-bundle checks it offline.

Preliminary findings need confirmation in the code; the full report gives the evidence, the limits of each check and how to re-test.